

External Vulnerability Assessment

EXTERNAL PENETRATION TEST AND VULNERABILITY ASSESSMENT

Client: NovaTech Cloud Solutions Testing Period: August 10 - August 14, 2026 Lead Assessor: Sarah Jenkins, OSCP

Executive Summary: Crestview InfoSec was engaged to perform a black-box external penetration test against the public-facing infrastructure of the NovaTech Customer Portal. The assessment utilized industry-standard methodologies, including the OWASP Top 10 framework. The objective was to identify security weaknesses that could be exploited by an unauthenticated attacker over the internet.

Overall Risk Posture: MEDIUM

Findings Breakdown: - Critical Vulnerabilities: 0 - High Vulnerabilities: 1 - Medium Vulnerabilities: 3 - Low Vulnerabilities: 4

Detailed High-Severity Finding: Vulnerability: Stored Cross-Site Scripting (XSS) Location: Customer Support Ticket Submission Form (`/api/v2/support/ticket`) CVSS v3.1 Score: 8.2 (High)

Description: The application fails to properly sanitize user-supplied input in the "Description" field of the support ticket submission form. An attacker can inject malicious JavaScript payloads into this field. When an authenticated administrator views the ticket in the backend portal, the script executes within the context of the administrator's session.

Proof of Concept: We successfully injected the payload `` into a test ticket. Upon opening the ticket via a dummy admin account, the session cookie was successfully exfiltrated to our external listener.

Remediation Recommendation: Implement strict input validation and context-aware output encoding. All user-supplied HTML tags should be stripped or properly escaped using a secure library (e.g., DOMPurify) before being rendered in the browser. Do not rely solely on client-side validation.

Next Steps: We recommend that the NovaTech development team prioritize the remediation of the Stored XSS vulnerability. Upon patch deployment, Crestview InfoSec will conduct a targeted retest to verify the effectiveness of the implemented fix.